

STRATUM CAPITAL BANK

Enterprise Governance & Risk Framework

CHAPTER 11

Enterprise Operational Risk, Enterprise Risk Management & Risk Appetite Framework

Classification	CONFIDENTIAL – INTERNAL USE ONLY
Version	5.4.1
Document Owner	Chief Risk Officer
Approved By	Board Risk Committee
Review Frequency	Annual or upon material change
Effective Date	1 January 2025
Next Review Date	31 December 2025

11.1 Purpose

This Chapter establishes the comprehensive Enterprise Operational Risk Management Framework (EORMF) and the overarching Enterprise Risk Management (ERM) structure for Stratum Capital Bank (hereinafter "the Bank" or "SCB"). The Framework sets out the governance, methodology, processes, controls, and reporting mechanisms by which the Bank identifies, assesses, monitors,

controls, and reports on all material risks to which it is or may become exposed in the conduct of its business activities.

This document has been prepared in accordance with the Basel Committee on Banking Supervision (BCBS) Principles for Operational Risk Management, the Financial Stability Board (FSB) guidance on enterprise risk governance, the Prudential Regulation Authority (PRA) and Financial Conduct Authority (FCA) supervisory expectations, and the Bank's own internal governance standards and policies.

11.1.1 Enterprise Risk Objectives

The Board of Directors of Stratum Capital Bank has established the following enterprise risk objectives, which form the foundational pillars of the Bank's risk management philosophy and operating model:

- Preserve and protect the Bank's capital base, liquidity position, and franchise value against unexpected and expected losses arising from all risk categories within the defined risk taxonomy.
- Ensure that risk-taking activities are conducted within the Board-approved Risk Appetite Statement (RAS) and that all material deviations are promptly identified, escalated, and remediated.
- Maintain regulatory compliance across all jurisdictions of operation and uphold the highest standards of ethical conduct, market integrity, and customer protection.
- Embed a robust, forward-looking risk culture throughout the organisation whereby all employees understand their risk responsibilities and actively contribute to the effective identification and management of risk.
- Achieve sustainable risk-adjusted returns by aligning the risk and business strategy and ensuring that the cost of risk is appropriately reflected in pricing, performance management, and capital allocation decisions.
- Maintain operational resilience and the ability to continue critical business services in the face of severe operational disruptions, cyber incidents, and systemic market events.
- Advance the Bank's responsibilities with respect to environmental, social, and governance (ESG) risks, with particular focus on climate-related financial risks as defined by the Task Force on Climate-related Financial Disclosures (TCFD) and regulatory guidance.

11.1.2 Risk Governance

The Bank operates under a governance structure that defines clear lines of accountability, responsibility, and escalation for risk management activities from the Board through to individual business units and support functions. The Risk Governance Framework is structured as follows:

- The Board of Directors retains ultimate accountability for the risk management framework and the setting of risk appetite.
- The Board Risk Committee (BRC) provides dedicated non-executive oversight of risk matters and approves the Risk Appetite Statement, Enterprise Risk Framework, and all material risk policies on an annual basis.

- The Chief Risk Officer (CRO) is responsible for the independent oversight and challenge of risk-taking activities across the Bank and reports directly to the Chief Executive Officer (CEO) and the Board Risk Committee.
- Senior management within each business line is accountable for the day-to-day management of risk within their areas of responsibility and for adherence to approved risk appetite and policy.

11.1.3 Three Lines of Defence Model

Stratum Capital Bank applies the Three Lines of Defence (3LoD) model as the primary organisational framework for risk management and internal control. The 3LoD model defines the roles, responsibilities, and reporting relationships of each line as follows:

First Line of Defence — Business Ownership and Risk Ownership

The first line of defence comprises all revenue-generating business units, client-facing functions, and operational support functions that own and create risk as a consequence of their daily activities. The first line is responsible for identifying, assessing, owning, and managing risk within approved appetite and in accordance with all applicable policies and procedures. Business Risk Officers (BROs) embedded within each division serve as the primary risk management liaison between the business and the Second Line.

Second Line of Defence — Independent Risk Oversight

The second line of defence comprises the Enterprise Risk Management function, the Compliance function, the Financial Crime function, and other specialist control functions. The second line is responsible for setting the risk management framework, policies, methodologies, and tools; for providing independent oversight and challenge of first line risk activities; for monitoring adherence to risk appetite and regulatory requirements; and for reporting risk positions to senior management and the Board. The second line does not own transactional risk but retains authority to escalate concerns and invoke risk response actions where required.

Third Line of Defence — Independent Assurance

The third line of defence comprises the Internal Audit function, which provides independent, objective assurance to the Board and senior management regarding the design and operating effectiveness of the risk management framework and internal control environment. Internal Audit operates in accordance with the International Standards for the Professional Practice of Internal Auditing and reports functionally to the Board Audit Committee.

11.1.4 Risk Culture

The Board and executive leadership of Stratum Capital Bank are committed to the development, maintenance, and continuous strengthening of a sound risk culture across the organisation. Risk culture is defined as the system of values, behaviours, competencies, and accountabilities that shape all risk-related decisions and actions within the Bank.

The key attributes of a sound risk culture at SCB include: a "tone from the top" that demonstrates visible commitment to responsible risk management; the empowerment of all employees to raise risk concerns without fear of reprisal; clear accountability for risk outcomes linked to performance evaluation and compensation; transparency and accuracy in internal and external risk reporting; and

an environment in which near misses, control failures, and emerging risks are proactively identified and shared.

Risk culture is assessed on a periodic basis through the use of conduct and culture surveys, internal audit findings, operational loss trends, regulatory feedback, and qualitative assessments by the CRO function. Findings are reported to the Board Risk Committee on a semi-annual basis.

11.2 Enterprise Risk Governance

The Enterprise Risk Governance structure of Stratum Capital Bank defines a comprehensive hierarchy of accountability for risk management from Board level to individual business lines. This section describes the roles, responsibilities, and interactions of each governance body within the risk management architecture.

11.2.1 Board of Directors

The Board of Directors holds the highest level of accountability for the Bank's risk management framework. In discharging its risk governance responsibilities, the Board:

- Approves the Bank's overall risk strategy, risk appetite, and risk management framework on at least an annual basis.
- Satisfies itself that the executive management team has implemented a risk management and internal control system that is adequate, effective, and commensurate with the size, complexity, and risk profile of the Bank.
- Reviews and challenges significant risk exposures, risk limit breaches, and risk-related management information presented by the CRO and the Board Risk Committee.
- Promotes a sound risk culture and holds senior management accountable for adherence to the approved risk appetite and governing policies.
- Oversees the independence and adequacy of the Internal Audit function and receives regular reports from the Head of Internal Audit.
- Ensures that material risks arising from strategic initiatives, mergers and acquisitions, and new product approvals are subject to rigorous risk assessment prior to Board sanction.

11.2.2 Board Risk Committee

The Board Risk Committee (BRC) is a dedicated Board-level committee composed of a majority of independent Non-Executive Directors with relevant risk management expertise. The BRC meets at a minimum on a quarterly basis, and on an ad hoc basis in the event of material risk events or emerging risks requiring Board-level attention. The BRC's mandate includes:

- Reviewing and recommending to the full Board for approval the Bank's Risk Appetite Statement, Enterprise Risk Framework, and material risk policies.

- Monitoring the Bank's overall risk profile against approved appetite and thresholds, and challenging management where risk positions exceed or approach defined limits.
- Overseeing the activities of the Chief Risk Officer and the Risk Management function, including review of enterprise risk reports, stress test results, and scenario analyses.
- Assessing the adequacy of the Bank's capital and liquidity positions relative to the risk profile and regulatory requirements.
- Reviewing significant risk events, operational losses, regulatory findings, and material control failures, and satisfying itself that appropriate remedial actions are in place.
- Reviewing and endorsing the Bank's Internal Capital Adequacy Assessment Process (ICAAP) and Internal Liquidity Adequacy Assessment Process (ILAAP) prior to submission to the regulator.

11.2.3 Chief Risk Officer

The Chief Risk Officer (CRO) is a senior executive with direct accountability for the Bank's independent risk management function. The CRO reports to the CEO for day-to-day administrative matters and has a direct reporting line to the Board Risk Committee for risk matters. Key responsibilities of the CRO include:

- Developing, maintaining, and implementing the Enterprise Risk Management Framework, Risk Appetite Statement, and all risk-related policies and methodologies.
- Providing independent oversight, challenge, and escalation in respect of risk-taking activities across all business lines and support functions.
- Leading the enterprise risk management team, comprising heads of credit risk, market risk, liquidity risk, operational risk, technology and cyber risk, compliance risk, model risk, and climate risk.
- Presenting the enterprise risk report to the Board Risk Committee on a quarterly basis, summarising the Bank's risk profile, material risk events, KRI trends, stress test outcomes, and emerging risks.
- Ensuring that risk management practices remain aligned with evolving regulatory requirements, industry best practice, and the Bank's strategic objectives.
- Serving as the Bank's primary liaison with prudential and conduct regulators on risk governance matters.

11.2.4 Business Units

Business unit heads bear primary accountability for managing risk within their respective areas of responsibility. Each material business unit is supported by a designated Business Risk Officer (BRO), who serves as the risk management focal point for that unit. Business units are responsible for:

- Implementing and adhering to the Bank's risk management policies and procedures within their daily operating activities.
- Maintaining a current risk and control self-assessment (RCSA) for their area of operation and updating it in response to changes in business activities, processes, systems, or the external environment.

- Identifying, recording, and escalating operational risk events, loss events, and near misses in accordance with the operational loss management procedures set out in Section 11.11.
- Monitoring business-level KRIs and taking timely corrective action when thresholds are breached.
- Completing mandatory risk training and embedding risk management considerations in day-to-day decision-making.

11.2.5 Compliance Function

The Compliance function, led by the Chief Compliance Officer (CCO), forms part of the second line of defence and is responsible for:

- Developing, maintaining, and implementing the compliance risk management framework, including policies, procedures, and monitoring programmes covering regulatory compliance, financial crime prevention, conduct risk, and data privacy.
- Providing independent oversight and advisory services to business units on compliance matters, including regulatory change impact assessments and pre-approval of new products and services from a compliance perspective.
- Monitoring and testing compliance with applicable laws, regulations, rules, and internal standards, and reporting compliance risk positions to the Board Risk Committee.
- Managing the Bank's regulatory relationships, including coordination of regulatory inspections, responses to supervisory requests, and timely submission of regulatory filings and notifications.

11.2.6 Internal Audit

The Internal Audit function provides the third line of defence and is responsible for providing independent, objective assurance over the effectiveness of the risk management framework, control environment, and governance processes. Internal Audit:

- Develops and executes a risk-based audit plan approved by the Board Audit Committee, which covers all material risk categories and business areas within a defined audit cycle.
- Reports audit findings and recommendations to senior management and the Board Audit Committee, tracking remediation of agreed actions to closure.
- Provides an annual opinion to the Board on the overall adequacy and effectiveness of the Bank's internal control framework.
- Maintains independence from operational and risk management functions and does not perform management activities or implement controls.

11.3 Risk Appetite Framework

The Risk Appetite Framework (RAF) of Stratum Capital Bank provides the overarching structure within which risk appetite is defined, communicated, monitored, and governed. The RAF ensures that the Bank's risk-taking activities are conducted within boundaries that protect capital, liquidity, reputation, and regulatory standing, while enabling the pursuit of sustainable financial returns.

11.3.1 Risk Appetite Statement

The Risk Appetite Statement (RAS) is a formal declaration approved by the Board that articulates the types and quantum of risk that the Bank is willing to accept in pursuit of its strategic objectives. The RAS is expressed through a combination of qualitative statements and quantitative metrics, and is reviewed and approved by the Board on an annual basis or more frequently in the event of material changes to the Bank's strategy, business model, or risk environment.

Stratum Capital Bank's overarching risk appetite is defined as follows:

SCB Risk Appetite Statement

Stratum Capital Bank seeks to maintain a moderate and well-diversified risk profile. The Bank does not seek to maximise risk-taking. It is the Bank's stated appetite to preserve capital adequacy above regulatory minima under all but the most extreme stress scenarios; to maintain liquidity positions sufficient to withstand a severe 30-day stress outflow; to achieve positive risk-adjusted returns across all material business lines; to suffer no material regulatory sanctions or findings of significant harm to customers; and to maintain a reputation as a trusted and responsible financial institution.

11.3.2 Risk Tolerance

Risk tolerance defines the maximum level of risk that the Bank is prepared to accept before escalation, remediation, or risk treatment actions are required. Risk tolerance levels are established for each material risk category and are expressed in quantitative terms where practicable. Tolerances are set below risk capacity and above risk appetite, creating a defined range within which management has discretion to operate without Board intervention. The following principles govern risk tolerance-setting:

- Tolerances are calibrated relative to the Bank's available capital and liquidity resources, earnings capacity, and regulatory requirements.
- Tolerances are expressed in multiple metrics, including absolute loss thresholds, ratio-based metrics (e.g. CET1 ratio floors), and qualitative indicators (e.g. number of critical regulatory findings).
- Tolerance breaches trigger mandatory escalation to the CRO and, where material, to the Board Risk Committee.
- Tolerances are reviewed at least annually and following any significant change to the Bank's risk profile or operating environment.

11.3.3 Risk Capacity

Risk capacity defines the maximum level of risk that the Bank is able to assume before breaching regulatory capital requirements, contractual obligations, or operational viability constraints. Risk

capacity represents an absolute ceiling and is not a target or preferred operating point. The Bank's risk capacity is determined with reference to:

- Available regulatory capital resources and minimum capital requirements under CRD V / CRR II as applicable.
- Available liquidity resources and minimum Liquidity Coverage Ratio (LCR) and Net Stable Funding Ratio (NSFR) requirements.
- Operational capacity constraints including system capacity, processing thresholds, and counterparty exposure limits.
- Legal and contractual constraints arising from debt covenants, derivative agreements, and regulatory permissions.

11.3.4 Risk Limits

Risk limits translate the Risk Appetite Statement and risk tolerance parameters into specific, operationally enforceable thresholds for individual risk types, business lines, portfolios, and exposures. The limit framework is structured hierarchically:

Limit Type	Description	Governance Owner
Enterprise Limits	Board-approved; apply across the entire Bank	CRO, Board Risk Committee
Portfolio Limits	Divisional; approved by RMC for material portfolios	CRO, Business Unit Heads
Desk / Position Limits	Granular trading / credit limits	Business Risk Officers
Concentration Limits	Single name, sector, and geography caps	CRO, Credit Committee

Limit breaches are subject to mandatory escalation and management response within defined timeframes. Temporary limit overrides may be approved by the CRO for a defined period, subject to a remediation plan and subsequent Board Risk Committee notification for material overrides.

11.3.5 Escalation

A clearly defined escalation protocol governs the identification, reporting, and management of risk appetite breaches and threshold exceptions. The escalation protocol specifies:

- **Amber Zone:** Risk exposure approaches tolerance threshold (>80% utilisation). Business unit head and BRO notified; increased monitoring frequency; formal management action plan required within five business days.
- **Red Zone:** Risk exposure breaches tolerance threshold (>100% utilisation). CRO notified within 24 hours; Risk Management Committee (RMC) notified at next scheduled meeting or within three business days for material breaches; formal remediation plan required within ten business days.

- Critical Zone: Risk exposure approaches or breaches risk capacity limits. CEO and Board Risk Committee notified within 24 hours; emergency RMC convened; contingency plan activated; regulatory notification considered.

11.3.6 Board Approval

The Board of Directors, acting through the Board Risk Committee, retains exclusive authority to approve the Risk Appetite Framework and the Risk Appetite Statement. No material change to risk appetite, tolerance, or enterprise-level limits may be implemented without prior Board Risk Committee approval. The following governance requirements apply:

- The RAS and RAF are presented to the Board Risk Committee for review and approval on an annual basis as part of the strategic planning cycle.
- Material interim changes arising from strategic developments, regulatory changes, or material risk events are presented to the Board Risk Committee at the next available meeting or, in urgent circumstances, through a written resolution process.
- The CRO presents a formal certification to the Board annually confirming that risk management practices remain within approved appetite and that the RAF remains fit for purpose.

11.4 Risk Taxonomy

The Stratum Capital Bank Risk Taxonomy provides a comprehensive, structured classification of all material risks to which the Bank is or may become exposed. The taxonomy is the foundation of the Bank's risk identification, assessment, and reporting activities, and ensures consistency in risk categorisation across all business lines, geographies, and governance levels.

11.4.1 Credit Risk

Credit risk is the risk of financial loss arising from the failure of a counterparty, borrower, or issuer to meet its contractual financial obligations to the Bank in full and on time. Credit risk encompasses default risk, counterparty credit risk (CCR) arising from derivative and securities financing transactions, concentration risk, and residual risk arising from credit risk mitigation techniques. Credit risk is the Bank's most significant risk category by regulatory capital consumption.

11.4.2 Market Risk

Market risk is the risk of losses in on- and off-balance-sheet positions arising from movements in market prices, including interest rates, foreign exchange rates, equity prices, and commodity prices. Market risk includes interest rate risk in the trading book, foreign exchange risk, equity risk,

commodity risk, and basis risk. The Bank manages market risk through VaR-based and sensitivity-based limit frameworks, stress testing, and hedging programmes.

11.4.3 Liquidity Risk

Liquidity risk is the risk that the Bank is unable to meet its financial obligations as they fall due without incurring unacceptable costs or losses. Liquidity risk encompasses funding liquidity risk (the risk of being unable to fund assets or meet liabilities at a reasonable cost) and market liquidity risk (the risk of being unable to sell or unwind positions at or near their carrying value). The Bank maintains a Contingency Funding Plan (CFP) and manages liquidity positions against regulatory LCR and NSFR requirements.

11.4.4 Operational Risk

Operational risk is the risk of loss resulting from inadequate or failed internal processes, people, and systems, or from external events. Operational risk is inherent in all products, activities, processes, and systems of the Bank. The Bank's operational risk framework encompasses the full range of operational risk sub-categories, including process failures, human error, system failures, fraud, and external events, as further defined in Section 11.5.

11.4.5 Cyber Risk

Cyber risk is the risk of financial loss, operational disruption, reputational damage, or regulatory sanction arising from a failure to protect the Bank's information systems, data, and technology assets from cyber threats. Cyber threats include ransomware, distributed denial of service (DDoS) attacks, data exfiltration, supply chain compromise, and insider threats. Cyber risk is overseen by the Chief Information Security Officer (CISO) and the Technology Risk function within the second line of defence.

11.4.6 Technology Risk

Technology risk is the risk that weaknesses in the Bank's information technology infrastructure, applications, change management processes, or IT governance give rise to operational disruptions, data integrity failures, or inability to deliver critical business services. Technology risk encompasses IT availability risk, IT change risk, IT capacity risk, data management risk, and end-of-life system risk.

11.4.7 AI Risk

Artificial intelligence risk encompasses the risks arising from the development, deployment, and operation of AI and machine learning models within the Bank's products, processes, and risk management activities. AI risk includes model accuracy risk, bias and fairness risk, explainability risk, data quality risk, adversarial risk, and regulatory non-compliance risk. AI risk management is

governed by the Model Risk Management Policy and the AI Governance Framework described in Section 11.16.

11.4.8 Compliance Risk

Compliance risk is the risk of legal or regulatory sanctions, material financial loss, or reputational damage that the Bank may suffer as a result of its failure to comply with applicable laws, regulations, rules, standards, and codes of conduct. Compliance risk is managed by the Compliance function as part of the second line of defence and encompasses regulatory compliance, conduct compliance, data privacy compliance, and sanctions compliance.

11.4.9 Strategic Risk

Strategic risk is the risk of adverse outcomes arising from poor strategic decisions, inappropriate implementation of strategic decisions, or failure to respond adequately to changes in the competitive, economic, technological, or regulatory environment. Strategic risk is inherently forward-looking and is assessed through the Bank's annual strategic planning process and ongoing environmental scanning activities.

11.4.10 Reputation Risk

Reputation risk is the risk that adverse publicity or negative public perception regarding the Bank's business practices, products, services, or conduct will lead to a loss of customer confidence, business, or market value. Reputation risk can arise as a consequence of other risk events (e.g. a significant operational failure or regulatory sanction) and is therefore considered a second-order risk. Reputational risks are monitored through media monitoring programmes, stakeholder feedback, and the Bank's social licence assessment.

11.4.11 Climate Risk

Climate risk encompasses the financial risks arising from climate change and the transition to a lower-carbon economy. Climate risk is categorised as: (i) physical risk, arising from the increased frequency and severity of extreme weather events and long-term climate shifts; and (ii) transition risk, arising from changes in policy, regulation, technology, and market sentiment associated with the transition to a net-zero economy. The Bank manages climate risk in accordance with the TCFD framework and the PRA's supervisory statement SS3/19.

11.4.12 Third Party Risk

Third party risk is the risk that the use of external service providers, suppliers, and outsourcing arrangements gives rise to operational disruption, data protection failures, regulatory non-compliance, or financial loss. Third party risk management encompasses vendor due diligence,

contractual protections, ongoing monitoring, and exit planning in accordance with the Bank's Third Party Risk Management Policy.

11.4.13 Legal Risk

Legal risk is the risk of loss arising from inadequate contractual documentation; changes in law or regulatory requirements; unenforceability of contractual rights; litigation and dispute resolution; and regulatory enforcement actions. Legal risk is managed by the General Counsel and Legal function in close coordination with the Compliance and Risk Management functions.

11.4.14 Conduct Risk

Conduct risk is the risk that the behaviours of the Bank or its employees lead to unfair outcomes for customers, market disruption, or damage to market integrity. Conduct risk management encompasses conflicts of interest management, product suitability assessments, sales conduct monitoring, remuneration structure review, and Senior Managers and Certification Regime (SM&CR) compliance.

11.4.15 Financial Crime Risk

Financial crime risk is the risk of loss, regulatory sanction, or reputational damage arising from the Bank's involvement in, or failure to prevent, financial crime activities including money laundering, terrorist financing, bribery and corruption, sanctions violations, insider dealing, and fraud. Financial crime risk is managed by the Financial Crime Compliance function under the authority of the Chief Compliance Officer.

11.5 Operational Risk Framework

The Operational Risk Framework (ORF) sets out the policies, methodologies, processes, and controls by which Stratum Capital Bank identifies, assesses, monitors, and manages operational risk across all business lines, legal entities, and geographic locations. The ORF is aligned with the Basel Committee's Principles for the Sound Management of Operational Risk and the Bank's regulatory capital methodology for operational risk.

11.5.1 Operational Events

An operational event is any occurrence arising from inadequate or failed internal processes, people, systems, or external events that results in, or has the potential to result in, financial loss, regulatory sanction, reputational damage, or customer detriment. Operational events are classified in

accordance with the Basel II / Basel III event type taxonomy, comprising seven primary categories: internal fraud; external fraud; employment practices and workplace safety; clients, products and business practices; damage to physical assets; business disruption and system failures; and execution, delivery, and process management.

All employees are required to report operational events promptly upon identification. The first line of defence is accountable for the initial recording of events in the operational risk management system (ORMS), which serves as the Bank's central repository for operational risk events, loss data, and near misses.

11.5.2 Loss Events

An operational loss event is an operational event that has resulted in a financial loss to the Bank. Loss events are recorded in the Bank's operational loss database with the following minimum data attributes:

- Event date and discovery date.
- Business line and cost centre attribution.
- Basel event type classification.
- Gross loss amount and any recoveries (including insurance recoveries).
- Net loss amount.
- Root cause analysis and control failure identification.
- Corrective action status and target completion date.

All loss events meeting or exceeding the Bank's minimum capture threshold (currently set at GBP 10,000 gross loss) must be recorded in the ORMS within five business days of discovery. Loss events involving potential regulatory reporting obligations must be escalated to the Compliance function immediately upon discovery.

11.5.3 Control Failures

A control failure is an operational event arising from the malfunction, circumvention, design inadequacy, or absence of a risk control. Control failures may or may not result in financial loss but represent a material vulnerability in the Bank's risk management architecture. Control failures are subject to root cause analysis, risk-based escalation, and enhanced monitoring until remediated. Systematic or recurring control failures are treated as indicators of a structural weakness in the control environment and are escalated to the CRO and, where material, to the Board Risk Committee.

11.5.4 Process Failures

Process failures encompass breakdowns in operational workflows, data flows, reconciliation processes, settlement procedures, and end-to-end transaction processing. Process failure risk is mitigated through process mapping, standardisation, automation, and the maintenance of up-to-date procedure documentation. Material process changes are subject to the Bank's Change Risk Management Policy, which requires a formal risk assessment and sign-off by the relevant BRO and second line risk function prior to implementation.

11.5.5 Human Error

Human error encompasses unintentional mistakes by employees that give rise to operational losses, customer detriment, or control failures. Human error risks are managed through training and competency assurance programmes, procedure adherence monitoring, maker-checker controls, automated input validation, and workload management practices. Patterns of human error are analysed to identify systemic causes including inadequate training, process complexity, or resource insufficiency.

11.5.6 System Failure

System failure encompasses the unavailability, degradation, or malfunction of the Bank's technology systems, applications, and infrastructure, whether arising from hardware failure, software defects, capacity constraints, cyber incidents, or third party technology failures. System failure risk is managed through IT resilience standards, disaster recovery planning, business continuity management, and the maintenance of defined Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs) for critical systems.

11.5.7 External Events

External event risk encompasses operational losses arising from events outside the Bank's direct control, including natural disasters, pandemics, civil unrest, utility failures, and criminal acts by external parties (e.g. cyber attacks, physical robbery, and payment fraud). External event risk is managed through business continuity planning, insurance programmes, scenario analysis, and engagement with industry-wide threat intelligence sharing forums. The Bank maintains a comprehensive Business Continuity Management (BCM) programme aligned to ISO 22301 and regulatory operational resilience requirements.

11.6 Risk Assessment

The Risk Assessment process provides the Bank with a systematic and structured approach to identifying, analysing, evaluating, and prioritising all material risks. The process is embedded within the Bank's Risk and Control Self-Assessment (RCSA) methodology and is conducted at the business unit, divisional, and enterprise levels on a defined cycle.

11.6.1 Risk Identification

Risk identification is the process of finding, recognising, and describing risks that could affect the achievement of the Bank's objectives. The Bank employs a range of risk identification techniques, including:

- Risk and Control Self-Assessments (RCSAs) conducted by first line business units on an annual basis and following material changes to the business environment.
- Process mapping and workflow analysis to identify inherent risks within operational processes.
- Review of internal loss data and near miss trends.
- Review of external operational loss data from consortium databases (e.g. ORX).
- Expert judgement and facilitated risk workshops involving cross-functional participants.
- Environmental scanning of regulatory guidance, industry publications, and peer disclosures to identify emerging and systemic risks.
- New product and activity approval processes, which require prospective risk identification prior to launch.

11.6.2 Risk Analysis

Risk analysis involves the determination of the likelihood and potential impact of identified risks. The Bank uses a two-dimensional risk matrix in which risks are assessed on scales of likelihood (from rare to almost certain) and impact (from negligible to catastrophic), across five dimensions of impact: financial loss; regulatory sanction; operational disruption; reputational damage; and customer detriment. Both inherent risk (before controls) and residual risk (after controls) are assessed.

11.6.3 Risk Evaluation

Risk evaluation involves comparing the estimated level of residual risk against the Bank's risk appetite, tolerance, and capacity thresholds to determine whether the risk is acceptable, requires further treatment, or necessitates escalation. Risks that exceed the defined appetite and tolerance thresholds are subject to a mandatory risk treatment decision and formal management response.

11.6.4 Risk Prioritisation

Risk prioritisation assigns relative priority to identified risks based on their assessed residual risk level, strategic significance, direction of travel (increasing, stable, or decreasing), and management confidence in the adequacy of existing controls. The Enterprise Risk Register is maintained by the CRO function and stratified into critical, high, medium, and low risk categories for reporting and governance purposes.

11.6.5 Risk Register

The Enterprise Risk Register is the Bank's master repository of all identified material risks. It records, for each risk: the risk description and category; the inherent risk assessment; the key controls in

place; the residual risk assessment; risk owner; KRI metrics and current status; escalation status; and any open risk treatment actions. The Enterprise Risk Register is maintained in the Bank's governance, risk, and compliance (GRC) system and is reviewed by the CRO function on a monthly basis and presented to the Risk Management Committee on a quarterly basis.

11.6.6 Control Assessment

Control assessment evaluates the design effectiveness and operating effectiveness of controls in place to mitigate identified risks. Design effectiveness assesses whether the control, if operating as intended, is capable of adequately mitigating the associated risk. Operating effectiveness assesses whether the control is in fact operating as designed. Controls are rated on a four-point scale: Strong, Adequate, Weak, and Absent. Controls rated Weak or Absent are subject to mandatory management action plans.

11.6.7 Residual Risk

Residual risk is the level of risk remaining after the application of existing controls. Residual risk is calculated as a function of inherent risk and control effectiveness. Where residual risk exceeds defined appetite thresholds, the Bank must implement one or more risk treatment options as described in Section 11.10. The aggregate residual risk profile of the Bank is summarised in the Enterprise Risk Report presented to the Board Risk Committee quarterly.

11.7 Key Risk Indicators (KRIs)

Key Risk Indicators (KRIs) are quantitative metrics designed to provide an early warning signal of increasing risk exposure or deteriorating control effectiveness. KRIs enable proactive risk management by alerting risk owners and oversight functions to developing adverse trends before they crystallise into risk events or losses.

11.7.1 Thresholds

Each KRI is assigned a Green/Amber/Red (RAG) threshold framework. Green thresholds represent the normal operating range consistent with risk appetite. Amber thresholds indicate elevated risk and trigger enhanced management attention and monitoring. Red thresholds represent a breach of risk tolerance and require immediate escalation and formal management response. Thresholds are calibrated by the CRO function in consultation with business line risk owners and are reviewed annually.

Key Risk Indicator	RAG Thresholds
KRI: Percentage of critical systems with expired DR tests	Green <5% Amber 5–15% Red >15%

Key Risk Indicator	RAG Thresholds
KRI: Number of P1/P2 operational incidents per month	Green <3 Amber 3–6 Red >6
KRI: Percentage of overdue audit actions (>30 days)	Green <10% Amber 10–20% Red >20%
KRI: Gross operational loss as % of gross income (rolling 12M)	Green <0.5% Amber 0.5–1.0% Red >1.0%
KRI: RCSA overdue beyond 12-month refresh cycle	Green 0% Amber 1–5% Red >5%
KRI: Regulatory findings rated High or Critical (open)	Green 0 Amber 1–2 Red >2
KRI: Staff risk training completion rate	Green >95% Amber 90–95% Red <90%
KRI: Third party critical supplier incidents per quarter	Green 0–1 Amber 2–3 Red >3

11.7.2 Monitoring

KRI monitoring is conducted by the first line of defence on a frequency commensurate with the materiality and volatility of each indicator — typically monthly for operational KRIs and daily for market and liquidity KRIs. The second line risk function aggregates KRI data through the Bank's GRC system and produces monthly KRI dashboards for review by the Risk Management Committee. All KRIs with an Amber or Red RAG status are subject to formal management commentary and corrective action documentation.

11.7.3 Escalation

KRI escalation follows the tiered protocol set out in Section 11.3.5. An Amber KRI status must be reported to the relevant BRO and business unit head within one business day of identification, with a management commentary and near-term action plan provided to the second line within five business days. A Red KRI status must be reported to the CRO within 24 hours, with an escalation report provided to the Risk Management Committee within three business days.

11.7.4 Dashboard

The KRI dashboard is a consolidated management information tool that provides a real-time or near-real-time view of the Bank's KRI profile across all risk categories and business lines. The dashboard is maintained in the Bank's GRC system and is accessible to all risk owners, the CRO function, and the Board Risk Committee. The dashboard displays current KRI values, RAG status, trend direction, and the status of any open management actions. A summarised version of the KRI dashboard is included in the quarterly Board Risk Committee pack.

11.7.5 Trend Analysis

KRI trend analysis involves the assessment of KRI data over time to identify patterns, deteriorating trajectories, and leading indicators of potential risk crystallisation. Trend analysis is performed by the second line risk function on a monthly basis and is presented in the quarterly Risk Management Committee and Board Risk Committee reports. KRIs exhibiting a sustained adverse trend over three or more consecutive reporting periods are subject to a formal risk deep-dive review, regardless of their current RAG status.

11.7.6 Reporting

KRI results are reported through the Bank's governance reporting hierarchy as follows: monthly at the Risk Management Committee level; quarterly to the Board Risk Committee; and annually in the Bank's ICAAP and ILAAP submissions. All KRI reports include current value, RAG status, trend direction, threshold calibration, and management commentary. Material KRI breaches are reported on an exception basis outside the standard reporting cycle.

11.8 Scenario Analysis

Scenario analysis is a key component of the Bank's Enterprise Risk Management Framework and is used to assess the potential impact of severe but plausible adverse events on the Bank's financial position, capital adequacy, liquidity, and operational resilience. Scenario analysis complements historical loss data by providing insight into the tail of the risk distribution and informing risk appetite, capital planning, and contingency planning decisions.

11.8.1 Macroeconomic Risks

The Bank conducts macroeconomic scenario analysis to assess the potential impact of severe economic downturns on credit quality, market positions, and earnings. Scenarios are aligned with the Bank of England's annual stress testing scenarios and the European Banking Authority (EBA) stress test methodology where applicable. Macroeconomic scenarios consider: sharp GDP contraction; rapid interest rate increases or decreases; property price corrections; unemployment spikes; and sovereign debt crises. The impact of each scenario on capital ratios, loan impairment charges, and net interest income is modelled and reviewed by the Board Risk Committee.

11.8.2 Cyber Events

Cyber scenario analysis assesses the potential financial, operational, and reputational impact of a material cyber incident, including a ransomware attack affecting core banking systems, a data exfiltration event affecting customer data, or a DDoS attack resulting in service unavailability. Cyber scenarios are developed with input from the CISO function and are benchmarked against industry

incident data and regulatory guidance. The scenarios assess direct costs (recovery, forensics, notification) and indirect costs (revenue loss, regulatory fines, reputational damage) over a 12-month horizon.

11.8.3 Pandemics

Pandemic scenario analysis assesses the Bank's resilience to a severe, prolonged public health emergency resulting in significant staff unavailability, supply chain disruption, elevated credit losses, and market volatility. The Bank's pandemic scenario draws on the experience of the COVID-19 pandemic and incorporates lessons learned with respect to remote working capacity, operational resilience, and credit portfolio behaviour under stress.

11.8.4 Fraud Events

Fraud scenario analysis assesses the potential impact of large-scale internal or external fraud events, including rogue trading, payment fraud, identity theft, and authorised push payment (APP) fraud. Fraud scenarios are calibrated using internal historical data, external loss consortium data, and regulatory guidance. The scenarios inform investment decisions in fraud controls and insurance programme design.

11.8.5 Liquidity Events

Liquidity scenario analysis assesses the Bank's ability to survive a range of liquidity stress scenarios, including a combined market-wide and idiosyncratic liquidity stress, a sudden loss of wholesale funding access, and a significant and unexpected deposit outflow. Liquidity scenarios are embedded in the Bank's ILAAP and inform the calibration of the Liquidity Coverage Ratio buffer and the Contingency Funding Plan.

11.8.6 Operational Disruption

Operational disruption scenario analysis assesses the potential impact of a severe and prolonged disruption to the Bank's critical operations, including the unavailability of a key technology platform, failure of a critical third party, or physical destruction of a key operational site. Operational disruption scenarios are integrated into the Bank's Business Continuity Management programme and inform the definition of impact tolerances and recovery objectives for critical business services.

11.9 Stress Testing

Stress testing is a risk management technique used to evaluate the potential effects of extreme but plausible adverse conditions on the Bank's financial soundness, capital adequacy, and liquidity position. The Bank's stress testing framework is aligned with the regulatory stress testing requirements of the PRA, the EBA, and the BCBS stress testing principles. Stress testing results inform the ICAAP, ILAAP, Recovery Plan, and Risk Appetite Statement.

11.9.1 Enterprise Stress Tests

Enterprise-level stress tests are comprehensive assessments of the Bank's resilience under a defined set of macroeconomic and financial market stress scenarios. Enterprise stress tests are conducted on an annual basis in alignment with the Bank of England's concurrent stress testing exercise and on a standalone basis under the Bank's own ICAAP schedule. The enterprise stress testing process involves: scenario design and parameter setting; impact modelling across credit, market, liquidity, and operational risk portfolios; management action overlays; and capital position projections under each scenario.

11.9.2 Reverse Stress Testing

Reverse stress testing is a process whereby the Bank identifies and assesses scenarios that would cause the Bank's business model to become unviable, i.e. scenarios that would exhaust the Bank's capital or liquidity resources or result in regulatory intervention. Reverse stress testing provides the Board with insight into the Bank's vulnerabilities and the scenarios under which the Bank's recovery plan would need to be activated. Reverse stress testing is conducted at least annually and the results are presented to the Board Risk Committee.

11.9.3 Sensitivity Analysis

Sensitivity analysis is used to assess the impact of changes in individual risk factors on the Bank's financial position, holding all other factors constant. Sensitivity analysis is used extensively in the management of market risk (e.g. delta, DV01, CS01 sensitivities) and is also applied in credit risk management to assess portfolio sensitivity to changes in probability of default, loss given default, and exposure at default assumptions.

11.9.4 Capital Impact

The capital impact of stress testing scenarios is assessed by projecting the impact of stressed losses and income on the Bank's CET1 ratio, Total Capital Ratio, and leverage ratio under each scenario. Capital projections are prepared by Finance in collaboration with the Risk Management function and are reviewed and challenged by the Board Risk Committee as part of the ICAAP process. Capital planning actions required to maintain capital adequacy above Board-approved floors under each stress scenario are documented in the ICAAP.

11.10 Risk Treatment

Risk treatment refers to the selection and implementation of options for addressing risks identified and assessed through the Bank's risk assessment process. The risk treatment decision is taken by the risk owner, informed by the residual risk assessment, risk appetite position, cost-benefit analysis of available treatments, and regulatory requirements. The following risk treatment options are available:

11.10.1 Accept

The Bank may choose to accept a risk where the residual risk level is within defined risk appetite and tolerance, where the cost of further risk reduction exceeds the expected benefit, or where no practicable risk reduction or transfer option is available. Risk acceptance must be documented, approved by the appropriate risk governance body, and subject to ongoing monitoring. All accepted risks above defined materiality thresholds require explicit sign-off by the CRO.

11.10.2 Reduce

Risk reduction involves the implementation of additional or enhanced controls designed to reduce the likelihood, impact, or both of a risk materialising. Risk reduction actions are documented in the Enterprise Risk Register with a named owner, a target completion date, and defined success criteria. Progress against risk reduction actions is monitored and reported by the second line risk function on a monthly basis.

11.10.3 Transfer

Risk transfer involves shifting the financial consequences of a risk to a third party, typically through insurance, hedging, or contractual risk allocation. The Bank maintains a comprehensive insurance programme that provides coverage for material operational risks including cyber incidents, professional indemnity, directors and officers liability, and property damage. Risk transfer decisions are made in consultation with the Treasury function (for financial hedges), the Procurement function (for contractual risk allocation), and the Insurance Risk Manager.

11.10.4 Avoid

Risk avoidance involves the decision not to engage in, or to cease, an activity that gives rise to an unacceptable risk exposure. Risk avoidance may be appropriate where a risk exceeds the Bank's risk capacity, where no effective risk reduction or transfer option is available, or where regulatory prohibition applies. Risk avoidance decisions of material significance require approval by the Risk Management Committee and notification to the Board Risk Committee.

11.10.5 Monitor

Where a risk is within appetite but requires attention, the Bank may decide to monitor the risk on an enhanced basis without taking immediate treatment action. Enhanced monitoring involves increased KRI measurement frequency, dedicated management information, and a pre-defined trigger for escalation to a more active treatment option. Monitoring is most commonly applied to emerging risks where the risk trajectory is uncertain and where the cost of premature risk treatment would be disproportionate.

11.11 Operational Loss Management

Operational loss management encompasses the processes by which the Bank records, investigates, analyses, and learns from operational risk events. An effective operational loss management programme is essential for the accurate measurement of operational risk, the timely identification of control weaknesses, and the continuous improvement of the operational control environment.

11.11.1 Incident Recording

All employees are required to report operational incidents, including actual losses, near misses, and control failures, through the Bank's incident reporting system (IRS) as soon as reasonably practicable following identification. The incident record must include: date and time of occurrence and discovery; description of the event; impacted business area and process; initial estimate of financial impact (if any); and the identity of the reporting employee. Failure to report incidents in a timely and accurate manner is treated as a conduct matter and subject to disciplinary action.

11.11.2 Loss Database

The operational loss database is the Bank's central repository of all recorded operational loss events and is maintained in the operational risk management system (ORMS). All recorded events meeting or exceeding the minimum capture threshold are included in the loss database. The loss database is used for: regulatory capital calculation purposes (where applicable); trend analysis and benchmarking; RCSA and scenario analysis calibration; and supervisory reporting. The loss database is reconciled to the Bank's financial ledger on a monthly basis to verify the accuracy and completeness of recorded loss amounts.

11.11.3 Near Misses

A near miss is an event that did not result in actual financial loss but, under slightly different circumstances, could have resulted in a material operational loss or customer detriment. Near misses are of significant value to the risk management function as they provide early warning of control weaknesses and vulnerability in business processes without the cost of an actual loss event. Near

misses are captured in the ORMS with a risk severity rating and are subject to root cause analysis. Near miss trends are reported in the quarterly operational risk report.

11.11.4 Root Cause Analysis

Root cause analysis (RCA) is conducted for all material loss events (gross loss above GBP 100,000), all Amber and Red rated control failures, and any systemic patterns identified in near miss or incident data. RCA is conducted by the first line of defence, with support from and independent validation by the second line risk function. The RCA must identify the direct cause, the contributing factors (process, system, people, or external), and the systemic or organisational factors that allowed the event to occur. RCA findings are recorded in the ORMS and used to inform corrective action development.

11.11.5 Corrective Actions

Corrective actions are risk mitigation measures developed in response to operational loss events, control failures, and root cause analysis findings. For each corrective action: a named accountable owner is assigned; a target completion date is defined; and a defined success metric is established. Corrective actions are tracked in the Bank's action tracking system and their progress is reviewed monthly by the second line risk function and reported to the Risk Management Committee. Overdue corrective actions are escalated to the CRO and, where material, to the Board Risk Committee.

11.12 Control Framework

The Control Framework defines the system of risk controls maintained by Stratum Capital Bank to mitigate identified risks to an acceptable residual level. Controls are classified by their primary function and are subject to regular design and operating effectiveness assessments as part of the RCSA process and Internal Audit programme.

11.12.1 Preventive Controls

Preventive controls are designed to reduce the likelihood of a risk event occurring. Examples include: access rights management and segregation of duties; transaction approval authorities and dual authorisation; mandatory training and competency assessments; new product approval processes; pre-trade compliance checks; and anti-money laundering screening. Preventive controls are the primary line of defence against operational risk events and are given the highest priority in the Bank's control investment decisions.

11.12.2 Detective Controls

Detective controls are designed to identify risk events, control failures, or policy breaches after they have occurred, enabling prompt management response. Examples include: transaction monitoring and anomaly detection systems; reconciliation and exception reporting processes; management information dashboards and KRI reporting; compliance surveillance systems; and internal and external audit programmes. The timeliness and accuracy of detective controls are critical determinants of the Bank's ability to limit the financial and reputational impact of risk events.

11.12.3 Corrective Controls

Corrective controls are designed to restore normal operating conditions following the occurrence of a risk event or control failure. Examples include: incident response procedures; business continuity and disaster recovery plans; customer remediation processes; and regulatory breach notification protocols. The adequacy and speed of corrective controls are key factors in limiting the total impact of operational risk events.

11.12.4 Compensating Controls

Compensating controls are additional controls implemented to reduce risk where the primary control is absent, weak, or temporarily impaired. Compensating controls are time-limited and are subject to a formal risk acceptance or management action plan while the primary control is being remediated. Examples include: enhanced manual oversight where automated controls are unavailable; increased sampling and spot-checking where system controls are degraded; and restricted access or suspension of activity where segregation of duties cannot be maintained.

11.12.5 Control Testing

Control testing encompasses both design effectiveness testing (assessment of whether the control is capable of mitigating the risk if operating as intended) and operating effectiveness testing (assessment of whether the control is functioning as designed in practice). Control testing is conducted by the first line (self-assessment), the second line (independent oversight testing), and the third line (Internal Audit assurance). Results of control testing are recorded in the ORMS and reflected in the residual risk ratings of associated risks in the Enterprise Risk Register.

11.13 Enterprise Reporting

The Enterprise Risk Reporting Framework provides a structured hierarchy of risk management information tailored to the needs of different governance levels within the Bank. Reports are designed to be accurate, timely, concise, and actionable, and are produced using the Bank's GRC system and management information tools.

11.13.1 Board Dashboard

The Board Risk Dashboard is a high-level summary of the Bank's risk profile, produced on a quarterly basis for presentation to the full Board and the Board Risk Committee. The dashboard presents: the overall enterprise risk appetite utilisation; the top ten risk exposures by residual risk rating; KRI RAG status by risk category; material risk events in the quarter; stress test outcomes; and emerging risks. The dashboard is designed to provide Board members with a clear, succinct, and visually accessible view of the Bank's risk position.

11.13.2 Executive Dashboard

The Executive Risk Dashboard is produced on a monthly basis for distribution to the CEO, CRO, CFO, and other members of the Executive Committee. It provides a more granular view of the Bank's risk profile than the Board dashboard and includes: business line risk appetite utilisation; detailed KRI trends; material operational losses and near misses; regulatory developments; and the status of material risk reduction actions.

11.13.3 Risk Dashboard

The operational Risk Dashboard is produced on a weekly basis by the second line risk function for internal use. It provides real-time or near-real-time visibility of KRIs, risk events, and control statuses across the Bank's operations. The operational dashboard is the primary management information tool used by BROs and risk managers in the day-to-day management of the Bank's risk position.

11.13.4 Heat Maps

Risk heat maps provide a visual representation of the Bank's risk profile, plotting identified risks on a two-dimensional matrix of likelihood and impact. Heat maps are produced for the overall enterprise risk profile and for individual risk categories. Colour coding (green, amber, red) provides immediate visual indication of risk concentration. Heat maps are included in the Board Risk Committee quarterly report and the ICAAP.

11.13.5 Risk Register

The Enterprise Risk Register (ERR) is presented to the Risk Management Committee on a quarterly basis and is available in summary form in the Board Risk Committee pack. The ERR provides a complete view of the Bank's identified material risks, their assessed inherent and residual risk levels, the key controls in place, and the status of any open risk treatment actions. The ERR is the definitive reference document for the Bank's risk profile.

11.13.6 Trend Reports

Trend reports analyse changes in the Bank's risk profile over time, identifying improving and deteriorating trends in KRIs, operational loss experience, control effectiveness, and regulatory compliance. Trend reports are produced on a quarterly basis and are designed to support the Board's forward-looking risk oversight. Areas of sustained adverse trend are subject to deep-dive review and specific management action.

11.14 Emerging Risk Management

Emerging risk management is the process by which the Bank identifies, assesses, and responds to risks that are new, evolving, or not yet fully understood, but which have the potential to materially affect the Bank's risk profile in the near to medium term. The Bank's Emerging Risk Forum, chaired by the CRO, meets on a quarterly basis to review and discuss emerging risk themes and to consider their implications for the Bank's risk management framework, strategy, and capital planning.

11.14.1 Artificial Intelligence

The rapid advancement and deployment of artificial intelligence and machine learning technologies across the financial services industry presents both significant opportunities and material risks for Stratum Capital Bank. Key emerging AI risks include: algorithmic bias and discriminatory outcomes in credit decisioning and customer service; the opacity of complex AI models undermining explainability and regulatory compliance; data poisoning and adversarial attacks on AI systems; the use of generative AI for fraud and social engineering; and the risk of systemic instability arising from correlated AI-driven decision-making across the financial system. The Bank's AI Governance Framework (Section 11.16) addresses these risks.

11.14.2 Quantum Computing

Quantum computing represents an emerging risk to the Bank's cryptographic infrastructure. Sufficiently powerful quantum computers could break widely used asymmetric encryption algorithms (such as RSA and ECC), potentially compromising the security of the Bank's communications, transaction authentication, and data storage. The Bank is engaged in a programme of post-quantum cryptography readiness, aligned with NIST's post-quantum cryptographic standards framework.

11.14.3 Geopolitical Risk

Heightened geopolitical tensions, including the risk of armed conflict, economic sanctions regimes, and deglobalisation trends, present material risks to the Bank's operating environment, market positions, counterparty exposures, and supply chain. The Bank monitors geopolitical developments through its country risk framework and its participation in industry intelligence forums. Geopolitical risk scenarios are incorporated into the Bank's stress testing and scenario analysis programme.

11.14.4 Climate Change

Climate change is identified by the Bank's Emerging Risk Forum as a structural and long-term risk with material implications for credit quality, market values, operational resilience, and regulatory compliance. The Bank integrates climate risk into its credit assessment, investment decision-making, and strategic planning processes, in alignment with the TCFD framework, the PRA's supervisory expectations, and the Bank's own Climate Risk Policy.

11.14.5 Supply Chain Risk

The increasing concentration and complexity of global supply chains, combined with the growing dependence of the financial services industry on a limited number of critical technology and data service providers, presents material concentration and single-point-of-failure risks. The Bank monitors supply chain concentration through its Third Party Risk Management programme and has implemented enhanced resilience requirements for critical service providers.

11.14.6 Digital Assets

The growth of digital assets — including cryptocurrencies, stablecoins, and tokenised securities — presents a range of emerging risks to the Bank, including: market and counterparty exposure to digital asset price volatility; potential financial crime risk arising from the pseudonymous nature of certain digital assets; regulatory uncertainty across multiple jurisdictions; and the risk of disintermediation of traditional banking functions by decentralised finance (DeFi) platforms. The Bank monitors regulatory developments in this space and has established a Digital Assets Working Group to assess strategic and risk implications.

11.15 Risk Culture

A sound, pervasive, and sustainable risk culture is fundamental to the long-term safety and soundness of Stratum Capital Bank. The Bank defines risk culture as the shared values, beliefs, behaviours, and knowledge that influence risk decisions across the organisation. This section sets out the key pillars of the Bank's risk culture programme.

11.15.1 Training

All employees of the Bank are required to complete mandatory risk management training on an annual basis. The mandatory curriculum includes: the Bank's risk management framework and policies; risk reporting obligations; fraud awareness and prevention; cyber security awareness; anti-money laundering and sanctions; conduct risk and the SM&CR; and data privacy. In addition to mandatory training, risk-specific training programmes are provided for employees with designated risk management responsibilities, including BROs, risk committee members, and senior managers.

11.15.2 Accountability

Accountability for risk management is embedded through the Bank's governance structure, the SM&CR regime, and individual performance management frameworks. Every employee is expected to understand their individual risk responsibilities, to identify and report risks within their area, and to comply with all applicable risk policies and procedures. Senior managers and material risk takers are subject to individual accountability requirements, including the maintenance of Statements of Responsibilities that clearly document their personal obligations with respect to risk management.

11.15.3 Ethics

The Bank expects all employees to conduct themselves with integrity, honesty, and in compliance with the law and the Bank's Code of Conduct at all times. Ethical behaviour in risk management includes: the accurate and transparent reporting of risk information; the escalation of concerns about potential misconduct or risk policy breaches; the avoidance of conflicts of interest; and the prioritisation of customer interests and market integrity in all business activities. The Board and executive leadership are committed to modelling and reinforcing ethical behaviour through their own conduct and communications.

11.15.4 Whistleblowing

The Bank maintains a confidential whistleblowing programme that enables employees to raise concerns about potential wrongdoing, regulatory breaches, or ethical violations through secure and anonymous channels, including a dedicated whistleblowing hotline and web portal managed by an independent third party. The Bank prohibits retaliation against employees who make good faith disclosures in accordance with the whistleblowing policy. The Audit Committee receives a quarterly report on whistleblowing disclosures and the outcomes of associated investigations.

11.15.5 Conduct

The Bank manages conduct risk in accordance with the FCA's Consumer Duty requirements and the Conduct Risk Policy. Key conduct risk management activities include: the assessment of product value propositions and distribution strategies; monitoring of sales quality and advice suitability; management of conflicts of interest; and oversight of employee remuneration structures to ensure alignment with customer and market integrity outcomes. Conduct risk indicators are monitored through the Bank's KRI framework and reported to the Board Risk Committee.

11.15.6 Performance Management

Risk culture is embedded in the Bank's performance management framework through the inclusion of risk management behaviours and outcomes in individual performance objectives and remuneration

decisions. Variable compensation for senior managers and material risk takers is subject to risk adjustment, including malus and clawback provisions, where individuals have been found to have materially breached risk policies, engaged in misconduct, or contributed to material risk events through inadequate risk management.

11.16 Model Risk Integration

Model risk is the risk of adverse consequences arising from decisions based on incorrect or misused models. The Bank uses a wide range of quantitative models in credit assessment, market risk measurement, liquidity management, fraud detection, regulatory capital calculation, and AI-driven decision support. The Model Risk Management (MRM) Policy provides the governance and control framework for all models within the Bank's model inventory.

11.16.1 AI Models

AI and machine learning models are subject to enhanced model risk management requirements reflecting their complexity, opacity, and potential for unintended behavioural outcomes. AI model risk management requirements include: pre-deployment validation of model performance, accuracy, fairness, and robustness; documentation of model purpose, training data, feature selection, and architectural choices; explainability assessment to ensure that model outputs can be understood and challenged by decision-makers and regulators; ongoing performance monitoring, including data drift and concept drift detection; and annual independent model review.

11.16.2 Credit Models

Credit risk models, including probability of default (PD), loss given default (LGD), and exposure at default (EAD) models, are used in credit approval, portfolio management, and regulatory capital calculation. Credit models are subject to the Bank's model validation framework, which requires pre-implementation validation, annual performance review, ongoing benchmarking against realised outcomes, and independent review by the Model Validation function at least every three years or following material methodology changes.

11.16.3 Fraud Models

Fraud detection models, including transaction scoring models, network analysis models, and identity verification models, are critical components of the Bank's financial crime prevention programme. Fraud model risk management includes: regular performance back-testing against realised fraud events; threshold calibration to balance fraud capture rates against false positive rates; bias and fairness assessments to ensure that model outputs do not disproportionately impact protected customer groups; and regular updates to reflect evolving fraud typologies.

11.16.4 Validation

All models are subject to independent validation by the Model Validation function before deployment and on a periodic basis thereafter. Validation encompasses: conceptual soundness review; analysis of the accuracy, stability, and robustness of model outputs; assessment of model limitations and the appropriateness of management overlays; and benchmarking against alternative modelling approaches. Validation findings are recorded in individual model validation reports and presented to the Model Risk Governance Committee.

11.16.5 Monitoring

Ongoing model monitoring is the responsibility of the model owner (first line) and the Model Risk Management function (second line). Monitoring activities include: tracking model performance metrics against defined benchmarks on a monthly or quarterly basis; monitoring the stability and representativeness of input data; detecting data drift and model degradation; and triggering model redevelopment or recalibration when performance metrics fall below defined thresholds.

11.16.6 Independent Review

All material models are subject to independent review by the Model Risk Management function or Internal Audit on a risk-based cycle. Independent review includes an assessment of the overall adequacy of the model risk management framework as applied to each model, the adequacy of documentation, the appropriateness of validation outcomes, and the effective implementation of recommended model adjustments. Results of independent reviews are reported to the Model Risk Governance Committee and, for material model risk findings, to the Board Risk Committee.

11.17 Continuous Improvement

The Bank is committed to the continuous improvement of its Enterprise Risk Management Framework. The continuous improvement programme ensures that the framework remains fit for purpose, aligned with evolving regulatory expectations, and reflective of lessons learned from risk events, internal assessments, and external benchmarking.

11.17.1 Risk Reviews

Formal risk reviews are conducted on a scheduled and event-driven basis. Scheduled reviews include: the annual RCSA refresh across all business units; the annual review of the Enterprise Risk Register; and the annual review and update of the Enterprise Risk Management Framework and all material risk policies. Event-driven reviews are triggered by material risk events, significant regulatory changes, strategic initiatives, or adverse findings from Internal Audit or regulatory inspection.

11.17.2 Lessons Learned

The Bank operates a structured lessons learned programme to ensure that insights from operational risk events, near misses, regulatory findings, audit actions, and stress test exercises are documented, disseminated, and incorporated into improvements to the risk management framework and control environment. Lessons learned are reviewed at the quarterly Risk Management Committee and relevant themes are incorporated into risk training programmes and the annual framework update.

11.17.3 Framework Updates

The Enterprise Risk Management Framework is subject to a formal annual review and update cycle, coordinated by the CRO function. Framework updates are informed by: regulatory guidance and supervisory expectations; industry best practice and peer benchmarking; internal risk event and near miss experience; Internal Audit recommendations; and strategic developments. All material changes to the Framework are approved by the Board Risk Committee prior to implementation.

11.17.4 Policy Reviews

All risk management policies owned by the CRO function are subject to a minimum annual review and are updated on a more frequent basis where required by regulatory change, material risk events, or organisational changes. Policy updates are approved by the appropriate governance body (as specified in the policy itself) and communicated to all affected employees through the Bank's policy management and communication channels.

11.18 Document Control

11.18.1 Definitions

Term / Abbreviation	Definition
Basel Committee (BCBS)	The Basel Committee on Banking Supervision, which sets global standards for bank prudential regulation.
BRC	Board Risk Committee — the dedicated Board-level committee responsible for oversight of risk management.
BRO	Business Risk Officer — the designated first line risk management focal point within each business unit.

Term / Abbreviation	Definition
CET1	Common Equity Tier 1 capital — the highest quality form of regulatory capital.
CRO	Chief Risk Officer — the senior executive responsible for the independent risk management function.
EAD	Exposure at Default — the expected credit exposure at the time of counterparty default.
ERM	Enterprise Risk Management — the integrated framework for managing all material risks.
GRC	Governance, Risk and Compliance — the integrated software platform used to manage risk and control information.
ICAAP	Internal Capital Adequacy Assessment Process — the Bank's internal assessment of capital requirements.
ILAAP	Internal Liquidity Adequacy Assessment Process — the Bank's internal assessment of liquidity requirements.
KRI	Key Risk Indicator — a metric used to signal changing risk exposure levels.
LCR	Liquidity Coverage Ratio — the regulatory requirement to hold sufficient high-quality liquid assets to survive 30-day stress outflows.
LGD	Loss Given Default — the proportion of an exposure expected to be lost in the event of counterparty default.
MRM	Model Risk Management — the framework governing the development, validation, and use of quantitative models.
NSFR	Net Stable Funding Ratio — the regulatory requirement to maintain a stable funding profile relative to assets.
ORMS	Operational Risk Management System — the Bank's central system for recording and managing operational risk events.
PD	Probability of Default — the likelihood of a counterparty defaulting within a defined horizon.
PRA	Prudential Regulation Authority — the UK prudential regulator for banks and insurers.
RAF	Risk Appetite Framework — the overall structure governing the setting and monitoring of risk appetite.

Term / Abbreviation	Definition
RAS	Risk Appetite Statement — the Board-approved statement of the types and quantum of risk the Bank is willing to accept.
RCSA	Risk and Control Self-Assessment — the process by which business units identify and assess their risks and controls.
RMC	Risk Management Committee — the senior management committee responsible for risk oversight below Board level.
SM&CR	Senior Managers and Certification Regime — the UK regulatory framework for individual accountability in financial services.
TCFD	Task Force on Climate-related Financial Disclosures — the international framework for climate risk disclosure.

11.18.2 Cross References

Document	Relevant Sections
Chapter 5 — Credit Risk Management Policy	Credit risk appetite, credit approval framework, impairment methodology
Chapter 6 — Market Risk Policy	Market risk appetite, VaR methodology, trading book management
Chapter 7 — Liquidity Risk Policy	Liquidity risk appetite, LCR/NSFR management, Contingency Funding Plan
Chapter 9 — Compliance Risk Framework	Regulatory compliance, conduct risk, financial crime
Chapter 10 — Technology & Cyber Risk Policy	IT risk management, cyber resilience, data security
Chapter 12 — Business Continuity Management	Operational resilience, BCM framework, recovery objectives
Chapter 14 — Model Risk Management Policy	Model governance, validation standards, MRC reporting
Chapter 15 — Climate Risk Framework	TCFD alignment, physical and transition risk management
Chapter 17 — Third Party Risk Management Policy	Vendor due diligence, outsourcing risk, supplier monitoring
ICAAP (standalone document)	Capital adequacy assessment, stress testing methodology, Pillar 2 capital

Document	Relevant Sections
ILAAP (standalone document)	Liquidity adequacy assessment, funding risk, liquid asset buffer
Recovery Plan (standalone document)	Recovery options, triggers, governance, and communication protocols

11.18.3 Policy Supremacy Statement

Policy Supremacy

This Chapter forms part of the Enterprise Governance & Risk Framework of Stratum Capital Bank and has been approved by the Board Risk Committee. In the event of any conflict or inconsistency between this Chapter and any subordinate policy, procedure, guideline, or business-level document, the provisions of this Chapter shall prevail, unless a specific written exemption has been approved by the Chief Risk Officer. Any such exemption must be documented, time-limited, and subject to review at the next available Risk Management Committee meeting.

11.18.4 Appendices

Appendix A — Enterprise Risk Register Template

The standard Enterprise Risk Register template includes the following fields: Risk ID; Risk Category (per Section 11.4 taxonomy); Risk Title; Risk Description; Inherent Likelihood (1–5); Inherent Impact (1–5); Inherent Risk Rating; Key Controls; Control Effectiveness Rating; Residual Likelihood (1–5); Residual Impact (1–5); Residual Risk Rating; Risk Owner; KRI Reference; Current KRI Status; Escalation Status; Risk Treatment Option; Treatment Action Description; Treatment Action Owner; Target Completion Date; and Action Status.

Appendix B — KRI Library

The KRI Library contains the full inventory of approved KRIs for each risk category, including KRI definition, data source, measurement frequency, Green/Amber/Red thresholds, reporting destination, and KRI owner. The KRI Library is maintained by the second line risk function and is reviewed and approved on an annual basis by the Risk Management Committee.

Appendix C — Scenario Analysis Summary

The Scenario Analysis Summary provides a description of each standard scenario used in the Bank's scenario analysis and stress testing programme, including scenario narrative, key assumptions, severity calibration, and reference to the most recent scenario analysis results. The Scenario Analysis Summary is updated on an annual basis and following significant changes to the Bank's risk environment.

Appendix D — Risk Governance Calendar

The Risk Governance Calendar sets out the schedule of Board, Board Risk Committee, Risk Management Committee, and other risk governance meetings and reporting obligations for the financial year, including the timing of ICAAP and ILAAP submissions, regulatory stress test submissions, annual RCSA refresh cycles, and policy review deadlines.

Appendix E — Escalation Matrix

The Escalation Matrix provides a consolidated reference guide for the escalation protocol applicable to each risk category, KRI, and operational event type, specifying the escalation trigger, escalation recipient, required escalation timeframe, and required escalation deliverable. The Escalation Matrix is reviewed and updated annually and following any material change to the governance structure.

Document Version Control

Version 5.4.1 | Approved: Board Risk Committee | Approval Date: 1 January 2025 | Author: Chief Risk Officer | Review Date: 31 December 2025 | Classification: CONFIDENTIAL – INTERNAL USE ONLY. This document is the property of Stratum Capital Bank. Unauthorised reproduction, distribution, or disclosure is strictly prohibited.